SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad **Esma Sarıtop** | Grup **4B Gündüz** | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Üç şart: (1) VAR — SBOM'da Component X (PLC firmware kütüphanesi) listeli mi? (2) Sürüm ETKİLENİYOR — kurulu 2.4, CVE'nin etkilenen aralığında mı? (3) ULAŞILABİLİR — zafiyetli servis/port ağdan erişilebiliyor mu? Üçü de evetse etkiler; CVSS 9.8 tek başına karar değildir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır; önce etki ve erişilebilirlik değerlendirilir, plansız duruş da risktir. Açık dışarıdan erişilemiyorsa ve telafi edici önlem varsa üretim sürer; sömürü belirtisi varsa veya erişim kapatılamıyorsa kontrollü durdururum. Karar ve gerekçe kaydedilir.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: üretici bülteni okunur, PLC program/konfigürasyon yedeği alınır; yama üretimde değil test ortamında (yedek PLC / sanal test) denenir. Sonra planlı bakım penceresinde, geri dönüş (rollback) planıyla uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet etkileyebilir: Safety PLC / sürücü STO-SLS, mute-hız parametreleri, safety haberleşmesi veya sertifikalı firmware (CRC/sürüm) değişiyorsa etki analizi (SF1–SF5) yapılır; yama sonrası E-stop, ışık perdesi, STO/fren testleri yapılır, etkileniyorsa safety yeniden doğrulanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Telafi edici önlem: zafiyetli servis/portu kapatmak veya firewall ile engellemek; Z2'ye yalnız izinli protokol/cihaz; uzak erişim varsayılan kapalı + jump server/MFA; Z1 (safety) izolasyonu; anormal trafik/log izleme ve alarm; USB/servis laptop kontrolü. Yama için bakım tarihi ve tedarikçi takibi planlanır; kalan risk (residual risk) için kabul eden sorumlu yazılır.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

LABORATUVAR 6 · GENEL SÜRÜM · Servo Elektrikli Abkant Pres

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad **Esma Sarıtop** | Grup **4B Gündüz** | Tarih

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

   Aranacaklar: tesis/OT güvenlik sorumlusu ve bakım amiri, ardından üretim müdürü ve servis sağlayıcı (IT/SOC varsa o da). İlk üç eylem: (1) Emniyeti güvene al — makineyi kontrollü şekilde güvenli duruma getir (üretimi durdur), ramın sabit olduğunu ve E-stop/ışık perdesi/STO'nun çalıştığını doğrula; PLC konfigürasyonu değişmiş olabileceği için makineye güvenme. (2) Şüpheli servis oturumunu/uzak erişimi kes, hesabı askıya al — resetleme, güç kesme yok. (3) Zaman damgalı olay notu başlat: ne görüldü, kim haberdar edildi, kim ne yaptı.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Emniyet: safety fonksiyonları (E-stop, ışık perdesi, kapı kilidi, STO/fren) test edilir; Safety PLC konfigürasyonu ve CNC mute/hız parametreleri son sağlam yedekle karşılaştırılır, doğrulanana dek makine üretime alınmaz. Kanıt: jump server/VPN/firewall ve oturum logları, PLC/CNC konfigürasyonunun salt okunur kopyası, saat bilgisi korunur; reset/yeniden yükleme yapılmaz. Hesap: ele geçirilen paylaşılan servis hesabı kapatılır, parolalar yenilenir, açık oturumlar sonlandırılır.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Hazır olmalı: olayın ne zaman/nasıl fark edildiği, etkilenen makine ve yazılım sürümü, şüphelenilen tür (yetkisiz erişim), olası etki (emniyet etkilendi mi?), alınan ilk önlemler. Kesin kök neden gerekmez; amaç hızlı ve dürüst ilk bildirim.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (güvenlik/IT log analizi): hesap nasıl ele geçirildi. Etki (bakım mühendisi): hangi PLC/CNC parametreleri değişti, safety etkilendi mi. Önlem: hesap kapatma, MFA + kişisel hesap, temiz yedekten geri yükleme; üretim müdürü yeniden devreye alma onayını verir.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Korunmuş olmalı: jump server/VPN/firewall logları, servis hesabı oturum kayıtları, PLC/CNC konfigürasyon yedekleri (önce/sonra, hash), safety test kayıtları, olay zaman çizelgesi ve kararlar, delil zinciri; kayıtlar korumalı log'da saklanır.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

LABORATUVAR 7 · GENEL SÜRÜM · Servo Elektrikli Abkant Pres

AI Safety Challenge

Çıktı: AI Fail-Safe Decision

Ad Soyad **Esma Sarıtop** | Grup **4B Gündüz** | Tarih

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari YZ'nin **dışında** tanımlanmalıdır.
Araçlar: fail-safe · human override · monitoring · confidence threshold · fallback.

Kamera → YZ Modeli → OK / RED → Parametre → Robot

Görev — üç başarısızlıkta güvenli davranış

1. **Model yanlış sınıflandırdı:** Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

   Sistem tek bir YZ kararına güvenmemeli: OK sonrası bağımsız ikinci kontrol (boyut/ağırlık ölçümü, ikinci model veya örnekleme) ve kritik parçada insan onayı olmalı. Hata oranı monitoring ile izlenir, sapmada hat durdurulur. YZ yalnız kalite kararı verir; ram/robotun güvenli hareketi YZ'den bağımsız safety yolunda kalır (Prediction ≠ Safety).

2. **Girdi manipüle edildi:** Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

   Fark etme: sensör/girdi doğrulama (kare sayacı, zaman damgası, imza), kameralar arası veya ikinci model ile çapraz kontrol, girdi dağılımı izleme (anomali tespiti), donma/bağlantı kopması kontrolü. Şüpheli girdide: karar kullanılmaz, fail-safe duruma geçilir (robot durur / parça reddedilir), alarm üretilir, insan kontrol eder ve olay kaydedilir.

3. **Confidence düştü:** Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

   Eşik risk analizinden çıkar ve doğrulama verisiyle test edilir (örnek: ≥ 0.90; safety açısından kritik kararda daha yüksek). Eşik altında otomatik karar yok: parça ayrılır/reddedilir, fallback (kural tabanlı/klasik kontrol) devreye girer, belirsizlikte insana sorulur; tekrarlayan düşüşte hat güvenli durur. Eşik değişikliği yetkili ve kayıtlı olmalı.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	Human override + bağımsız ikinci kontrol + monitoring: OK kararı ikinci ölçümle doğrulanır, hata oranı izlenir; şüphede parça reddedilir / hat durur (fail-safe).
Girdi manipüle edildi	Fail-safe + monitoring: girdi doğrulama ve anomali tespiti; şüpheli girdide YZ kararı kullanılmaz, robot güvenli duruma geçer, insana alarm gider (human override).
Confidence düştü	Confidence threshold + fallback: eşik altında otomatik karar yok; parça ayrılır, insana sorulur veya klasik kontrole düşülür; tekrarında hat durur (fail-safe).

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 + EP 15** başlığına oturur.